

Declaration.

- If the Certification Declaration contains the `authorized_paa_list` field, the following validation SHALL be done:
 - The Subject Key Identifier (SKI) extension value of the PAA certificate, which is the root of trust of the DAC, SHALL be present as one of the values in the `authorized_paa_list` field.
- The `certificate_id` field SHOULD match the `CDCertificateID` field found in the entry of the `DeviceSoftwareCompliance` schema in the `Distributed Compliance Ledger` where the entry's `VendorID`, `ProductID` and `SoftwareVersion` field match the respective `VendorID`, `ProductID` and `SoftwareVersion` attributes values found in the `Basic Information Cluster`. For further clarity, a scenario where a mismatch is most likely to occur is with devices that have received an updated firmware but not an updated CD.
 - If the `certificate_id` does not match the `CDCertificateID` field due to the above point, a Commissioner SHOULD NOT reject the Commissionee. Instead, the Commissioner SHOULD check that there is an entry with the `VendorID`, `ProductID` and `SoftwareVersion` in the `DeviceSoftwareCompliance` from the `Distributed Compliance Ledger` to validate that the current version is certified. For the case of offline commissioning without access to DCL, the Commissioner SHOULD proceed trusting that a valid CD matching the reported `VendorID` and `ProductID` at least ensures the device has been previously certified and SHOULD check the DCL at a later time to ensure the current `SoftwareVersion` is also certified.
- The `firmware_information` field in the `Attestation Information`, if present, SHALL match the content of an entry in the `Distributed Compliance Ledger` for the specific device as explained in [Section 6.3.2, “Firmware Information”](#). If the Commissioner does not support Firmware Information validation, it MAY skip checking this match.

The order of execution of the above validation steps MAY be optimized by Commissioners. For example, if some validation steps are deemed by a Commissioner to make the remainder of the steps unnecessary because they have no chance of succeeding, then the validation steps could be ordered such that superfluous steps or rounds trips are omitted.

6.2.4. Device attestation revocation

The `Distributed Compliance Ledger` contains a trusted list of revocation distribution points for the Device Attestation PKI. The schema is documented in [Section 11.23.9, “Device Attestation PKI Revocation Distribution Points Schema”](#).

The format of certificates in the Device Attestation PKI is constrained to maximum sizes and a specific format to reduce the complexity and system requirements for Device and Commissioner implementations. Therefore, there are no requirements for common revocation information, such as `cRLDistributionPoints` (see [RFC 5280](#) section 4.2.1.13) to be included. Furthermore, OCSP (see [RFC 6960](#)) is not used in order to allow Commissioner implementations which rely on previously cached revocation information, or which do not have concurrent access both to the public Internet and to the Commissionee when commissioning. The `Device Attestation PKI Revocation Distribution Points Schema` in the `Distributed Compliance Ledger` is thus the main method of delivering interoperable and universally accessible revocation information for Matter Commissioners and Adminis-